

**Bridging Psychology and Cybersecurity: Building an AI System to Identify and Describe
Manipulation Tactics in Complex Scam Messages**

Vishnu Rao

Lone Star Honors College Montgomery

Independent Research Project

Professor William Moon

Introduction

In the modern era, phishing and other forms of digital scams are the direct cause of cataclysmic levels of financial damage and the numbers tell a sobering story: cybercrime damages have already wrought \$1 trillion worth of damages in 2024 globally (WEF, 2025; Rogers, 2024). and will likely hit \$1 trillion to 1.2 trillion in 2025 (Miliefsky, 2025). The effectiveness of phishing is bolstered by the fact that out of 859,532 cybercrime complaints the FBI received in 2024, phishing and spoofing topped the list (FBI, 2025). In fact, between 80 and 95 percent of security breaches start with phishing attempts and direct human action or error causes 68 percent of data breaches according to a Verizon cybersecurity industry report (The Verizon DBIR Team, 2024). This catastrophic level of havoc is enabled by social engineering (aka “people hacking”), and more specifically, a technique called pretexting where attackers create believable scenarios to extract sensitive information from targets; is the leading cause of cybersecurity incidents (The Verizon DBIR Team, 2024). Moreover, malicious actors manipulate cognitive biases such as urgency bias and systematically exploit the human desire to be helpful in order to build rapport and get victims to make quick faulty (and risky) decisions that can be exploited (Yao, 2025). All in all, with regards to social engineering and the modern cybersecurity landscape, the human mind is regarded as a potential security vulnerability, not just software systems.

Literature Review

Recent cybersecurity research with regards to analyzing phishing and digital scam messages with AI relates to two methodological families that dominate the literature. First are agentic LLM and RAG (Resource Augment Generation) approaches and second are fine tuned or NLP (Natural Language Processing) classifiers, which rely on labeled datasets, feature extraction, and transformer based deep learning. Both of these systems focus purely on structural, technical, linguistic, and contextual indicators of malicious content without explaining why the psychological manipulation works on a cognitive level. This creates a gap for research seeking to combine cybersecurity detection with psychologically grounded explanations.

Agentic LLM and RAG Approaches

Kurniawan et al (2024) presents CYKG RAG, a cybersecurity AI system that combines an AI knowledge graph with RAG to give large language models more reliable, structured context. For instance, by drawing on established cybersecurity resources such as MITRE ATT&CK, the system links threats, vulnerabilities, and attack techniques in a way that helps reduce typical LLM issues like hallucination and missing technical details. The authors demonstrate this through use cases involving cyber threat queries and log analysis, showing how structured retrieval improves the precision and relevance of LLM generated answers. Although the framework is effective for technical threat intelligence and system level cyber signals, it remains focused on technical indicators and doesn't extend into more human domains like psychological manipulation or social engineering.

Koide et al (2023) developed ChatPhishDetector, a phishing site detection system that uses large language models and a custom crawler that collects the final URL after redirects,

browser rendered HTML, OCR extracted text from screenshots, and full page context. Then, the system applies CoT (Chain of Thought) prompting to help the model identify impersonated brands, domain mismatches, deceptive layouts, and social engineering cues such as fake warnings or urgent payment demands. Thus, by reasoning through these elements in step by step manner, ChatPhishDetector achieves high accuracy up to 98.7% in precision and 99.6% in recall with regards to detecting phishing sites. However, its focus remains on structural and technical signals rather than the psychological mechanisms and cognitive biases that make these attacks persuasive, leaving a clear gap for systems designed to explain the underlying manipulative tactics.

Koide et al (2024) introduces ChatSpamDetector, a phishing email detection system that uses large language models by converting email content into analysis prompts that the LLM can classify with detailed reasoning, analyzing full email data including headers and body text to determine whether an email is phishing and provides explanations to help users understand its decisions. Evaluated on a comprehensive phishing dataset, ChatSpamDetector with GPT 4 achieves very high accuracy, surpassing several baseline systems because its strength lies in the LLM's ability to interpret contextual phishing tactics and impersonation cues from the email content. However, the focus remains on detecting technical and structural indicators within the email itself, rather than modeling the broader psychological mechanisms or cognitive biases that may make a message persuasive.

Similarly, Wang et al (2025) introduces SmishX, an LLM based system that explains how it detects SMS phishing. This framework doesn't just read the text of a message but also pulls in outside information like brand legitimacy, URL redirections, and screenshots of linked webpages and then it creates a short user friendly explanation to tie it all together. The overall system

performs extremely well, reaching 98.8% accuracy on a dataset of 1,200 messages and during two user studies with a total of 175 participants, people who read the AI's explanations became noticeably better at spotting smishing attempts, with the tool earned a usability score of 82.6 from its users. Nevertheless, its explanations mostly focus on the technical signs of phishing like strange URLs, odd formatting, sender inconsistencies, and suspicious metadata. Ultimately, it does not connect those signs to specific psychological concepts from peer reviewed research, like authority bias or urgency bias; so while SmishX offers clear, useful explanations, it still doesn't fully explain why these messages trick people on a psychological level.

Fine Tuned and NLP Based Classification Models

Celik et al (2025) presents an NLP based system specifically aimed at detecting phishing in financial emails, where attackers often impersonate banks, payment services, or customer support. They create a dataset of real and malicious financial messages and use traditional NLP techniques, mainly TF IDF keyword extraction combined with semantic similarity analysis, to separate phishing emails from legitimate ones. Their results show that using both keyword based features and semantic similarity together improves detection accuracy more than either method alone. While the system is effective technically, the paper focuses on classification methods and does not explore why these messages trick people. It doesn't address psychological factors, cognitive biases, or emotional triggers that make financial phishing persuasive. In short, the work strengthens detection performance but doesn't explain the human side of why these attacks succeed.

Mittal et al (2022) introduces the DARTH framework, a multi model phishing detection system that analyzes several parts of an email including body text, embedded URLs, and header metadata through separate neural network models and then fuses their outputs in an ensemble classifier. The study also applies NLP techniques such as BERT based text classification (Bidirectional Encoder Representations from Transformers), clustering, and sentence vector analysis to capture patterns like “masquerade ness” and “urgent ness” in phishing messages (Mittal et al, 2022). Across more than 150,000 emails, the combined ensemble of models used in the DARTH framework achieved extremely high performance, with precision and F scores near 99.98%. While the work demonstrates that multi faceted modeling substantially boosts detection accuracy, it focuses on technical signals rather than psychological factors or deeper analysis of deceptive tactics. As a result, it provides a powerful engineering baseline but does not address the human manipulation mechanisms that make phishing persuasive.

Hosseinzadeh et al (2025) presents a hybrid deep learning model for phishing email detection that integrates BERT with various encoded tools that help the model understand patterns and important details in emails, with its settings (called hyperparameters) optimized through the Mountain Gazelle Optimizer (MGO). The work demonstrates that using this adaptive optimization approach leads to strong classification performance (high accuracy, precision, recall, and F1 score) compared to traditional deep learning baselines using a publicly available email dataset. However the article does not incorporate explanations of psychological mechanisms under the human susceptibility to phishing, focusing instead on technical classification performance and the optimization of the model.

Gap in the Literature

Current phishing detection systems share a common weakness: both agentic LLM/RAG frameworks and fine tuned classifiers can identify malicious messages with impressive accuracy, but their explanations stop at the technical level. These systems point out suspicious URLs, detect sender spoofing, and flag impersonation attempts but what they cannot do is explain *why* these tactics work on people.

Take the recent agentic approaches: CYKG RAG (Kurniawan et al, 2024), ChatPhishDetector (Koide et al, 2023), ChatSpamDetector (Koide et al, 2024), and SmishX (Wang et al 2025) all detect technical red flags, yet none of them connect those red flags to validated theories about how cognitive biases actually function in the context of deception, leaving users aware of warning signs but no understanding of the psychological mechanisms that make those signs effective in the first place.

The fine tuned models have the same limitation. Systems like those from Celik et al (2025), the DARTH framework (Mittal et al, 2022), and various hybrid architectures (Hossein-zadeh et al, 2025) optimize for accuracy without building psychological theory into how they detect or explain threats.

Even recent work that explicitly examines cognitive manipulation demonstrates this gap as Yao et al (2025) identifies ten common cognitive biases exploited in phishing emails, including Authority Bias, Urgency Effect, Negativity Bias, and Conformity, and shows that incorporating these cognitive bias features into neural network models significantly improves detection performance, yet the system still operates as a classifier that recognizes bias patterns in text rather than explaining the psychological mechanisms to the user. For example, it doesn't

cover why Authority Bias makes fake CEO emails convincing or how urgency bias passes deliberative thinking.

What's currently evident is that there is a fundamental mismatch: phishing is a psychological manipulation problem, not just a text classification task. Attackers deliberately exploit authority bias, urgency bias, loss aversion, and our tendency to want to help others, yet current detection systems treat these manipulation tactics as mere patterns in text rather than theoretically grounded psychological attacks that leverage well documented cognitive vulnerabilities. A system might recognize that a message creates urgency, but it cannot explain how that urgency hijacks one's decision making or bypasses the rational thinking documented in behavioral economics research. In fact, current systems answer "Is this phishing?" very well but don't answer the arguably more important question: "Why does this message work on people, what psychological mechanisms make it effective?"

This logic matters in practice. Without psychologically grounded explanations, users learn to spot specific technical tricks but not the underlying persuasion principles that attackers adapt and repackage across different contexts, which means that even if someone successfully identifies one phishing attempt, they remain vulnerable to the next iteration because they never developed a transferable comprehensive understanding of how the manipulation operates. The educational value stays limited because people memorize rules without truly understanding what makes people vulnerable to these types of phishing/digital scam attacks.

Bridging the gap between technical detection with psychological explanations is key to resolving this fundamental disconnect as the cybersecurity field lacks an AI system capable of both accurately detecting phishing messages and articulating psychologically grounded explanations for the manipulative strategies used. To address this gap, this paper asks: Can an AI

powered RAG system, using only peer reviewed research in psychology, cybersecurity, and social engineering, accurately detect and explain the manipulative tactics and cognitive biases used in complex phishing and deceptive messages?

Methodology

Stage 1: Knowledge Base/Dataset Construction

The foundation of this system is a carefully curated database of peer reviewed research articles on psychology, cybersecurity, and social engineering. The dataset construction process started with retrieving 175,000 relevant articles using boolean search operators combined with the Entrez E Utils Search API from the PubMed Central (PMC) Open Access Subset. This initial collection included any article that might contain information about human psychology, deception, manipulation, or cybersecurity.

After removing duplicates, faulty articles, and articles with corrupted XML formatting, approximately 100,000 articles remained. Computational limitations made further filtering necessary to a selection of 50,000 articles so improving the code cycle after cycle would take much less time and through using a collection of approximately 800 keywords related to psychological manipulation and cybersecurity, like ‘social engineering’ and ‘dark triad’, the dataset was narrowed to 9,000 highly relevant articles stored in cleaned JSONL (JSON Lines) format. This taxonomy was built through an extensive review of pilot articles in the PMC Open Access Subset, identifying recurring technical terms, psychological concepts, and manipulation tactics across disciplines.

These 9,000 articles covered 8 major categories overall: Business Marketing Deception, Consumer Behavioral Economics, Psychological Manipulation, Criminology Fraud,

Communication Media, General Cognitive Psychology, Cybersecurity (with a social engineering focus), and Organizational Management. This broad categorization ensured comprehensive coverage of how manipulation works across different contexts within the academic field so that the final AI model can have various examples from various fields to draw and refer to when generating outputs.

The first script processes the 9,000 JSONL formatted articles and creates a chunked knowledge base. Each article's JSONL structure contains fields (called metadata) for title, abstract, sections, paper ID, publication year, and author information which enables source citation in responses and allows users to trace explanations back to specific research papers. Articles shorter than 500 characters were automatically filtered out to ensure only articles that had sufficient material made it into the knowledge base. This quality control step removed papers that were too brief to provide meaningful context for manipulation analysis. For each valid article, the text was tokenized by whitespace and chunked into 250 word segments with a 50 word overlap between consecutive chunks which prevents concepts or sentences from being split across chunk boundaries. Psychological principles or manipulation techniques discussed across multiple sentences remain contextually intact and are large enough to preserve multi-sentence explanations of psychological principles, but just small enough to fit multiple chunks within the model's context window, and optimized for the embedding model's 512 token processing limit.

Stage 2: Embedding/Search Index Construction

The second script builds a dual retrieval infrastructure using both semantic and keyword based search indices. For semantic search (search associated with direct meaning), the system employs the Sentence Transformers library with the all MiniLM L6 v2 model. This model is a

lightweight transformer specifically optimized for semantic similarity tasks, producing 384 dimensional dense embeddings that capture meaning rather than just keyword overlap. The model was pre-trained on massive datasets of sentence pairs, enabling it to understand that phrases like "urgent deadline" and "time pressure" are semantically similar even without shared words. Each of the knowledge base chunks was encoded into these 384 dimensional vectors through batch processing (batch size of 32) to manage memory efficiently.

These embeddings were then indexed using FAISS (Facebook AI Similarity Search), a highly optimized library for dense vector search. FAISS uses the L2 (Euclidean distance) metric to measure similarity between query embeddings and stored chunk embeddings, enabling rapid retrieval of the most semantically relevant research. The IndexFlatL2 configuration ensures exact nearest neighbor search rather than approximate methods, prioritizing accuracy over speed given the manageable dataset size of 9000 articles. For keyword based search, the system implements BM25 (Best Match 25), a keyword ranking tool widely used in information retrieval for RAG. The rank bm25 Python library provides an implementation of the BM25Okapi variant, which considers term frequency, inverse document frequency, and document length normalization. Each chunk was tokenized using NLTK (Natural Language Toolkit) with the punkt tokenizer, which handles sentence and word boundaries intelligently. BM25 excels at finding chunks where specific technical terms or phrases appear frequently, complementing FAISS's semantic understanding.

However, when analyzing a scam message, the AI model needs to retrieve the most relevant research to explain the manipulation tactics being used. Thus, this was accomplished through a dual retrieval approach combining FAISS and BM25.

First, FAISS performs semantic similarity search by comparing the embedded vector of the input message with all chunk vectors in the database using L2 (Euclidean distance) as the similarity metric. Then, the system retrieves the 15 chunks that are most semantically similar in meaning, even if they use different words or phrasing. For example, a message about "urgent account suspension" would retrieve research about fear based manipulation and authority bias, even if those exact phrases don't appear in the articles. This semantic matching is critical because phishing messages use everyday language while academic papers use technical terminology.

Second, BM25, implemented through the rank bm25 library, provides keyword based ranking using a probabilistic model that considers term frequency, inverse document frequency, and document length normalization. Text is tokenized using NLTK's punkt tokenizer, which intelligently handles sentence and word boundaries. BM25 retrieves the 15 chunks with the highest keyword relevance scores, excelling at finding chunks where specific technical terms like "phishing," "pretexting," or "cognitive bias" appear frequently. This keyword precision complements FAISS's broader understanding.

After both methods retrieve their top 15 candidates, the system removes duplicates (chunks that appear in both result sets of retrievals) and selects the first 5 unique chunks for final context. FAISS results are explicitly prioritized over BM25 results during deduplication because scam analysis fundamentally requires understanding semantic meaning and psychological principles rather than simple keyword overlap. This hybrid strategy addresses a practical challenge as scam messages use colloquial, euphemistic, or deliberately obfuscated language that differs substantially from academic or general diction which is easier to categorize. Semantic search finds conceptually related research even when vocabulary diverges, while BM25 ensures precision when technical terms are present. The 5 chunk limit balances information richness

against context window constraints. More chunks provide a broader perspective but risk exceeding the LLM's 4096 token context limit when combined with the query and system prompt.

Stage 3: Query Processing and Response Generation

The core system implements the retrieval and generation logic, loading the LLM and search indices into memory once at initialization and maintaining them across multiple queries. The base AI model used is called Phi-3-mini-4k-instruct-q4, a 3.8 billion parameter instruction tuned LLM quantized to 4 bits. This quantization reduces model size and memory requirements while maintaining strong performance on reasoning tasks. Phi 3 was selected because it balances capability with computational feasibility and it can run quite well on consumer hardware without GPU acceleration while still providing coherent, contextually appropriate responses. For context, the machine used for this project was an M1 Macbook Air computer with 8 gB of RAM which is quite small.

Also, Phi 3 was loaded using llama cpp python, a Python binding for the llama.cpp library that enables efficient CPU and GPU inference for .GGUF format models (a file extension for LLMs). Key parameters that were used for this research include a 4096 token context window which is objectively small (but large enough to give detailed responses), 6 CPU threads for parallel processing, and automatic GPU layer offloading when Metal or CUDA acceleration is available. Moreover, Phi 3's temperature was set to 0.7 to balance creativity with consistency, and a maximum output length of 800 tokens ensured detailed responses without excessive length. The top p (nucleus sampling) parameter was set to 0.9, meaning the model samples from the smallest set of tokens whose cumulative probability exceeds 90 percent, reducing the likelihood

of generating very low probability (potentially nonsensical) tokens. Overall, this three stage architecture (knowledge base/dataset construction, embedding/index building, and query processing) which were spliced into 3 different code scripts which created a maintainable, transparent, and extensible RAG system that can independently updated, such as adding more articles, switching embedding models, or adjusting retrieval parameters, without requiring full system retraining.

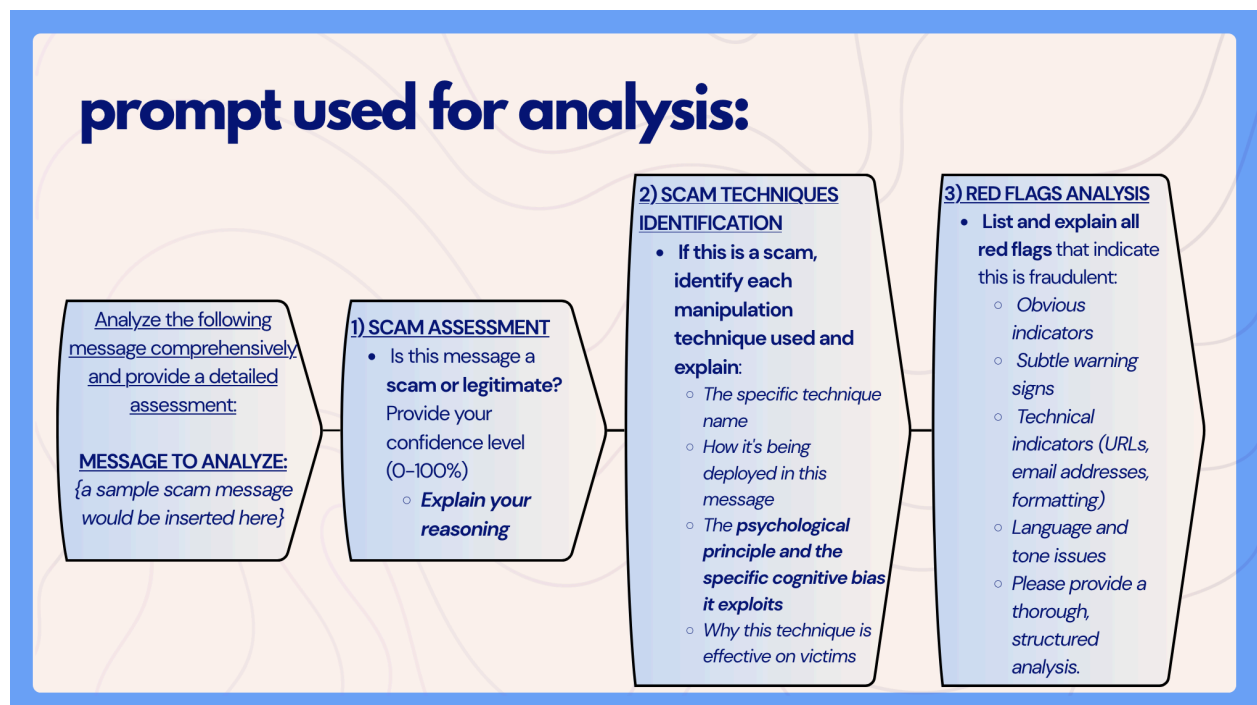
Sample Test Message Generation

To evaluate the system, 100 realistic scam messages were generated using three state of the art language models: ChatGPT 5.0, Grok 4.1, and Google Gemini 2.5 Fast. Each model was prompted to create realistic scam messages with varied formats and scam types, targeting approximately 225 words to ensure manageable token usage. The messages were fully detailed, human like, and properly formatted, resembling real world complex phishing attempts that people encounter.

The scam categories were randomized across nine common types: package delivery scams, tech support scams, romance scams, cryptocurrency scams, prize notifications, tax scams, job offers, invoice fraud, and account verification requests. These categories represent the most common vectors for social engineering attacks and challenging examples were manually selected during generation to ensure the test set included sophisticated attacks that might fool even cautious users. The test set ultimately contained 80 scam messages, 15 legitimate messages, and 5 ambiguous messages that could reasonably be interpreted either way.

Analysis Prompt for Example Scam Messages

The system analyzes messages using a structured three section prompt designed to extract comprehensive information about manipulation tactics and this prompt structure was deliberately designed for the LLM to return structured learning feedback.



This three section structure forces the model to provide layered analysis: classification with confidence (acknowledging uncertainty), psychological explanation (connecting tactics to cognitive science), and practical red flag identification (empowering users to spot similar attempts). Moreover, the prompt explicitly requests cognitive bias identification, ensuring responses engage with psychological theory rather than just describing surface features.

The retrieved research chunks are formatted with metadata (source chunk ID, paper title, and publication year) and provided as context before this prompt which allows the model to ground its explanations in specific research and enables source citation in responses. The

combined prompt (context plus query) typically occupies 2,300 to 3,000 tokens of the model's 4096 token context window, leaving 1,700 to 1,000 tokens for response generation.

Consequently, context window management was critical given the relatively small 4096 token limit. Long messages were noted during batch processing, as they risk token overflow when combined with retrieved context and the structured prompt. The 225 word target for various phishing and scam messages/queries (approximately 1,350 to 1,500 characters or 300 to 400 tokens) was chosen to ensure that even with retrieved context and prompt structure, the combined input would remain comfortably within the 4096 token limit.

Results

The system demonstrated strong performance in detecting both legitimate and malicious messages. Out of 15 legitimate messages, 13 were correctly identified as legitimate (86.67 percent accuracy). While this sample size limits statistical confidence, the result suggests strong legitimate message recognition. Out of 80 scam messages, 73 were correctly identified as scams (91.25 percent accuracy). These results show that the system can reliably distinguish between legitimate communications and social engineering attempts.

Beyond simple classification, the system successfully identified specific manipulation techniques, the psychological principles behind them, and the cognitive biases being exploited. In scam messages, the system consistently detected techniques such as urgency creation, authority manipulation, fear based persuasion, spoofing of legitimate brands, and fabrication of specific details to build false credibility as well as general technical and tonally related red flags.

Representative Example: Verbatim Adobe Invoice Scam and Successful Analysis

sample phishing message:

Subject: Adobe Invoice #AU-2025-1189472 Overdue – Immediate Action Required
Dear Valerie Martin,

This is the second and final reminder regarding Adobe Creative Cloud Annual Subscription invoice #AU-2025-1189472 dated 15 November 2025 for AUD \$959.88 (inc GST) billed to your NAB Visa Card. Payment attempted on 29 November 2025 was declined. Your Adobe account and all linked services (Photoshop, Lightroom, Premiere Pro) will be suspended in 24 hours unless settled today.

To avoid interruption and additional late fees of \$149.00, please review and pay the outstanding balance here: <https://adobe-billing.au/secure-payment/invoice/AU-2025-1189472>

If the card on file has expired or been replaced, update your payment method at the same secure link. For tax purposes, your ABN 31 298 765 401 has already been applied.

Questions? Contact Adobe Accounts Receivable on 1800 614 352 (Mon-Fri 8am-7pm AEDT) and quote invoice #AU-2025-1189472.

This is an automated notification. Do not reply directly.

sample successful analysis: part 1

1) SCAM ASSESSMENT

Confidence level: 95%

This message is likely a scam.

The high confidence level is based on several suspicious factors in the message, such as the urgent and threatening tone, the specific details that could be easily faked, and the request to update payment methods without any clear verification process.

2) SCAM TECHNIQUES IDENTIFICATION

– **Social Engineering:** The message uses urgency ("Immediate Action Required") and fear (suspension of services) to manipulate the recipient into acting hastily without proper verification.

– **Phishing:** The message attempts to collect sensitive information by asking the recipient to review and pay the outstanding balance through a provided link.

– **Spoofing:** The message contains a seemingly legitimate business address, but the URL link provided may not lead to an official Adobe website.

Psychological principles exploited:

– **Urgency and fear exploit loss aversion cognitive biases, leading to hasty decision-making.**

– **Trust and authority manipulation,** where the recipient assumes the message is legitimate due to the company's name.

sample successful analysis: part 2

3. RED FLAGS ANALYSIS

Obvious indicators:

- The message uses generic salutation "Dear Valerie Martin," which doesn't match a specific individual's name, suggesting a mass scam attempt.

Subtle warning signs:

- The use of a very specific invoice number and date, which could be easily fabricated by scammers.

Technical indicators:

- The link provided may not lead to an official Adobe website, which is a common red flag for phishing attempts.

Language and tone issues:

- The use of an aggressive and threatening tone, which is often seen in scam messages.

[Sources]

[Source 2019] Advances in Digital Payment Systems (2024)

[Source 3078] Research Paper on NFC-related cybersecurity threats and solutions. The research paper (2023)

[Source 2023] In the context-based on location attacks on mobile payment systems.

[Source 4848] A systematic review of literature on credit card cyber fraud detection using machine learning (2023)]

Discussion

The system's strong performance stems from several key design choices. First, by grounding all explanations in peer reviewed research, the system reduces speculation and provides evidence based analysis. When the system explains that a message exploits loss aversion bias, it can actually cite the given psychological research in it's database on how people respond to threats of losing things they value.

Second, the semantic first retrieval design (prioritizing FAISS over BM25) allows the system to understand manipulation at a conceptual level rather than relying on surface level keywords. A scammer might never use the word "manipulation," but semantic search can still find research about manipulative communication patterns.

Third, the structured prompting ensures comprehensive analysis across multiple dimensions: classification, technique identification, psychological explanation, and red flag

detection. This multi-layered approach provides users with multiple pathways to recognize manipulation.

An important advantage of this approach is that hallucinations (when the AI makes up false information) are relatively easy to detect. Since all claims should tie back to retrieved literature, a hallucinated citation is immediately visible as having no corresponding evidence which is exactly the transparency that is lacking in black box classification systems that simply output "scam" or "legitimate" with no explanation. Thus, the credibility of the information generated by this model is quite solid.

When the LLM makes errors or provides incomplete analyses, the solution is straightforward: add more relevant research articles to the database. If the system misses a particular manipulation tactic, it likely means the database lacks research on that specific technique and unlike fine tuned models that require retraining on new labeled data, a RAG system can be improved simply by expanding its knowledge base (within the very same day). This is made even easier by the modular programming style used to code the entire project, as any part of this system can be easily updated, maintained, and upgraded in the future.

This matters for cybersecurity training and defense against social engineering because it shifts the focus from technological solutions to psychological awareness. Instead of just blocking malicious emails, this approach helps users understand why they might have been tricked, building long term resistance. It treats cybersecurity education as a psychological intervention, not just a technical problem.

Limitations

This research represents a first iteration with several acknowledged limitations. The dataset size of 9,000 articles, while substantial, is still limited compared to the full scope of relevant research that could've been reaped because computational constraints prevented processing the full 100,000 articles initially filtered, and expanding beyond the PMC Open Access Subset would require access to additional research databases.

The analyses produced by the system were sometimes incomplete, particularly in explicitly naming all relevant cognitive biases. In some cases, the system would describe how a manipulation technique works psychologically but fail to use the formal terminology that would make the explanation more educational.

The system would also occasionally generate hallucinated citations, references to research sources that don't actually exist or weren't actually retrieved (or spout random numbers and characters instead). While these are detectable because of the evidence based framework, they still represent a reliability concern that needs addressing.

Future Work

Several directions could significantly enhance this system's capabilities. First, expanding the database from 9,000 to 20,000 or more articles would provide broader coverage of manipulation techniques and psychological principles. This expansion should include pulling from additional research repositories beyond PMC Open Access, such as IEEE Xplore, ACM Digital Library, and other academic databases.

Integration into practical applications represents another important direction as the framework could be built into an email security extension or mobile app that analyzes messages

in real time and provides users with educational feedback about manipulation tactics. This could possibly transform the system from a research and educational warning tool into a practical defense mechanism.

Upgrading to more powerful hardware and using larger, more capable language models would improve analysis quality and allow processing of the full article database and would also enable more sophisticated retrieval mechanisms and better explanation generation.

Conclusion

This paper demonstrates that bridging psychology and cybersecurity through an evidence based RAG system can successfully detect and explain manipulation tactics in phishing messages. Unlike traditional detection systems that focus solely on classification accuracy, this approach emphasizes explainability, psychological education, and grounding in peer reviewed research. The system successfully identifies not just whether a message is malicious, but why it's dangerous: which cognitive biases it exploits, which psychological principles make the manipulation effective, and which warning signs should alert careful readers. By restricting knowledge retrieval to peer reviewed literature, the system maintains credibility and transparency, making hallucinations detectable and allowing continuous improvement through database expansion.

As social engineering attacks become more sophisticated, understanding the psychology of manipulation may be our most important defense and creating psychologically aware cybersecurity tools that treat human factors not as vulnerabilities to be patched, but as capacities to be educated and strengthened may be the path forward.

Nevertheless, this work provides a foundation for building systems that don't just protect people from threats, but teach them to recognize manipulation in all its forms. Rather than simply blocking threats, this system can slow down decision-making and interrupt cognitive shortcuts, giving users the time and knowledge to think critically about potential manipulation. By delivering credible, research-backed explanations that work across diverse attack types, it builds a lasting psychological shield transforming cybersecurity from block box logic fueled protection into transparent education that empowers users to recognize deception in all its forms.

Sources

Github Repository (for all code and resources): https://github.com/Vishnu-Rao-1/cybersec_llm

Celik et al, L. (2025). *Enhancing Phishing Detection in Financial Systems through NLP*.

Enhancing phishing detection in financial systems through NLP.

<https://arxiv.org/html/2507.04426v1#bib.bib23>

El Zemity , A., Arief, B., & Li, S. (2025). *CyberLLMInstruct: A New Dataset for Analysing Safety of Fine Tuned LLMs Using Cyber Security Data*. CyberLLMInstruct: A new dataset for analysing safety of fine tuned LLMS using cyber security data.

<https://arxiv.org/html/2503.09334v2>

Global Cybersecurity Outlook 2025 WEF. (2025).

https://reports.weforum.org/docs/WEF_Global_Cybersecurity_Outlook_2025.pdf

Hosseinzadeh, M., Ali, U., Ali, S., Abbaszadi, R., Gharehchopogh, F. S., Khoshvaght, P., Porntaveetus, T., & Lansky, J. (2025, October 21). *Improving phishing email detection performance through deep learning with adaptive optimization*. Nature News.

<https://www.nature.com/articles/s41598-025-20668-5?>

IBM. (2025). *Cost of a data breach 2025*. <https://www.ibm.com/reports/data-breach>

IBM Cost of a Data Breach Report 2024. (2024). *Cost of a data breach report 2024*. Cost of a Data Breach Report 2024. [https://cdn.table.media/assets/wp-content/uploads/2024/07/30132828/Cost of a Data Breach Report 2024.pdf](https://cdn.table.media/assets/wp-content/uploads/2024/07/30132828/Cost-of-a-Data-Breach-Report-2024.pdf)

Koide, T. (2023). *Chatphishdetector: Detecting phishing sites using large language models | IEEE Journals & Magazine | IEEE Xplore*. ChatPhishDetector: Detecting Phishing Sites Using Large Language Models. <https://ieeexplore.ieee.org/document/10723311/>

Koide, T., Fukushi, N., Nakano, H., & Chiba, D. (2024, August 23). *Chatspamdetector: Leveraging large language models for effective phishing email detection*. arXiv.org.

<https://arxiv.org/abs/2402.18093>

Kurniawan, K. (2024). *CYKG rag: Towards knowledge graph enhanced retrieval*. CyKG RAG: Towards knowledge graph enhanced retrieval augmented generation for cybersecurity.

https://ceur-ws.org/Vol_3950/paper1.pdf

Miliefsky, G. (2025). The true cost of cybercrime: Why global damages could reach \$1.2 \$1.5 trillion by end of year 2025 Cyber Defense Magazine.

<https://www.cyberdefensemagazine.com/the-true-cost-of-cybercrime-why-global-damages-could-reach-1-2-1-5-trillion-by-end-of-year-2025/>

- Mittal, A. (2022). *SMU Data Science Review SMU Data Science Review Volume 6 number 2 summer 2022*. Phishing Detection Using Natural Language Processing and Machine Learning.
<https://scholar.smu.edu/cgi/viewcontent.cgi?article=1215&context=datasciencereview>
- Rogers, S. (2024, November 7). *International scammers steal over \$1 trillion in 12 months in New Global State of Scams Report*. GASA. <https://www.gasa.org/post/global-state-of-scams-report-2024-1-trillion-stolen-in-12-months-gasa-feedzai>
- The Verizon DBIR Team. (2024). *2024 data breach investigations report*. 2024 Data Breach Investigations Report. <https://www.verizon.com/business/resources/Te3/reports/2024-dbir-data-breach-investigations-report.pdf>
- Wang et al, Y. (2025). *Can you walk me through it? explainable SMS phishing detection using LLM based agents | Usenix*. Can You Walk Me Through It? Explainable SMS Phishing Detection using LLM based Agents.
<https://www.usenix.org/conference/soups2025/presentation/wang>
- Yao, Y. (2025). *The psychological manipulation of phishing emails: A cognitive bias approach sciencedirect*. The Psychological Manipulation of Phishing Emails: A Cognitive Bias Approach. <https://www.sciencedirect.com/org/science/article/pii/S1546221825009968>
- FBI releases annual internet crime report | Federal Bureau of Investigation. (2025a).
<https://www.fbi.gov/news/press-releases/fbi-releases-annual-internet-crime-report>